Protección de datos personales · Ecuador

Ingreso & Validación Itsanet · Arquitectura, datos, integraciones y mantenimiento

Contenido

1. Marco de protección de datos personales en Ecuador

2. Controles implementados y evidencia técnica

3. Acciones organizativas por acreditar

4. Datos corporativos y servicios Google

5. Demostraciones, capturas y aprobación

1. Marco de protección de datos personales en Ecuador

IV ITSANET trata identidades de usuarios, correo, autoría y fechas de trabajo. Las fotografías pueden contener datos personales si permiten identificar personas. SKU y cantidades de mercadería no son necesariamente datos personales por sí solos, aunque son información operativa que debe protegerse.

Referencia	Aplicación
Constitución de la República, art. 66 numeral 19	Protección de datos personales y decisión sobre su uso.
Ley Orgánica de Protección de Datos Personales (LOPDP)	Quinto Suplemento del Registro Oficial 459, 26/05/2021. Principios, bases de legitimación, derechos, seguridad y transferencias.
Reglamento General de la LOPDP, Decreto Ejecutivo 904	Tercer Suplemento del Registro Oficial 435, 13/11/2023. Desarrollo reglamentario.
Autoridad de control: Superintendencia de Protección de Datos Personales (SPDP)	Revisar resoluciones, criterios y disposiciones vigentes aplicables a la organización.

La ubicación en Quito no limita la aplicación nacional de este marco. Este documento describe controles técnicos y tareas de gobierno; no certifica cumplimiento integral ni sustituye el análisis del responsable del tratamiento y su asesoría especializada.

La consulta de los portales oficiales fue bloqueada por el entorno de generación. No se verificó la vigencia consolidada de resoluciones complementarias al 29/10/2026. Antes de aprobar la entrega normativa, contrastar el texto y normativa vigente en Registro Oficial y SPDP.

2. Controles implementados y evidencia técnica

Control	Implementación de referencia	Límite / verificación
Acceso por roles	OPERADOR, SUPERVISOR y ADMIN; comprobación en API.	Asignar permisos mínimos y revisar cuentas reales.
Credenciales	PBKDF2-HMAC-SHA256 con sal; cookie de sesión HttpOnly / SameSite=Lax.	Comprobar Secure y esquema HTTPS efectivo; no se acredita MFA.
Integraciones	Tokens cifrados con Fernet en SQL; clave externa protegida.	Esto no significa que toda la base o todo el disco estén cifrados.
Transporte	URL HTTPS publicada por Apache.	Verificar certificado vigente y confianza en handheld; revisar exposición de 3002.
Trazabilidad	Usuario, eventos, fechas, motivo de corrección y procesos.	No es registro WORM/inmutable frente al administrador SQL.
Archivos y permisos	Identidad de archivo, SHA-256 y copia Drive con checksum confirmado.	Verificar permisos reales de carpetas y destinatarios; un enlace no concede autorización por sí mismo.
Mediciones compartidas	Exportador con lista cerrada; omite usuario, SKU, recepción y referencias.	Persisten fechas y datos operativos agregables; tratar el JSON como información interna.

Fuentes: app/security.py, app/db.py, app/services/integraciones.py, archivos.py, google_drive_api.py y procesos.py. El inventario del servidor es evidencia compartida; la configuración efectiva debe conservarse en el control de infraestructura.

3. Acciones organizativas por acreditar

Materia	Acción y evidencia pendiente
Responsable y encargados	Identificar la persona jurídica que decide fines/medios y los proveedores que tratan datos por su cuenta; formalizar responsabilidades.
Finalidad y legitimación	Documentar finalidad de validación, auditoría y evidencias, categorías de titulares y base jurídica por tratamiento. No asumir consentimiento general como única base.
Información y derechos	Aviso de privacidad, destinatarios y conservación; canal y procedimiento de acceso, rectificación, eliminación y demás derechos aplicables. El flujo de derechos no está acreditado por la interfaz actual.
Minimización	Fotografiar mercadería; evitar rostros, identificaciones y pantallas ajenas. Limitar campos, exportaciones y acceso a evidencia.
Conservación	Aprobar plazos por categoría y obligaciones contractuales/legales; eliminación controlada en MySQL, servidor, Drive y respaldos. No se acredita borrado automático por plazos.
Análisis de riesgo	Evaluar amenazas, medidas y proporcionalidad; determinar si corresponde evaluación de impacto o delegado según la normativa aplicable.
Proveedores y transferencias	Revisar contrato, configuración, ubicación efectiva y mecanismos de transferencia de Google/otros proveedores.
Incidentes	Procedimiento de detección, contención, evaluación y notificación con responsables y plazos legales vigentes verificados.
Continuidad y accesos	Respaldos, ensayo de restauración, registro de revisión de usuarios y política de privilegios.

Estas acciones requieren evidencia institucional; no se marcan como cumplidas por existir Apache, MySQL o una conexión HTTPS.

4. Datos corporativos y servicios Google

Los datos operativos y metadatos se conservan en MySQL del servidor corporativo. Las evidencias e informes se copian a Google Drive y el correo se entrega mediante Gmail autorizado. Por tanto, no es correcto afirmar que toda la información permanece exclusivamente en el servidor o en Ecuador.

- Inventariar qué datos se envían a Drive/Gmail y para qué finalidad.
- Determinar las entidades proveedoras y condiciones contractuales aplicables, roles de tratamiento y subencargados.
- Verificar ubicación efectiva y transferencias internacionales; documentar la base y salvaguardas que correspondan. No asumir residencia local por usar una cuenta corporativa.
- Configurar acceso nominal o de grupos autorizados, revisar enlaces compartidos y evitar exposición pública injustificada.
- Conservar permisos, trazabilidad de entregas y procedimiento de revocación/retención.
- Conservar la clave de cifrado en respaldo protegido; no publicarla ni incluir tokens en presentaciones.

5. Demostraciones, capturas y aprobación

Las capturas incluidas muestran la interfaz del código en pruebas con información sintética. No constituyen evidencia de una operación productiva de hoy. Una captura productiva adicional debe revisarse antes de compartir para retirar datos personales, correos, usuarios, clientes y referencias que no sean necesarios.

Para la presentación: mostrar primero pantallas sin credenciales, usar una cuenta de prueba por rol, desactivar notificaciones visibles y no grabar datos identificables sin la autorización institucional y base correspondiente. El archivo HTML procesa el JSON y las capturas cargadas localmente; no los envía a un servicio remoto.

Cierre del control: registrar fecha de revisión, responsable del tratamiento, revisión técnica, revisión de normativa complementaria, acciones pendientes y aprobación que corresponda. No se inventan firmas ni se atribuye certificación a este expediente.